

THREAT ASSESSMENT WORKBOOK

Digital Content #6 — Shadow Agents: You Didn’t Authorize This Agent. It Didn’t Wait for You To.

Purpose: Assess your organization’s exposure to Shadow Agent threats — where an unauthorized autonomous AI agent, connected to corporate systems via OAuth delegation, takes actions on behalf of employees without security review or governance oversight. Map the detection gap, assign ownership, and build a prioritized response plan.

01 Exposure Check

Answer Yes / No / Unknown for your environment. Every Unknown is a gap. Three or more Unknowns = this is your next tabletop agenda.

Question	Yes	No	Unknown / Gap Notes
Do we have a current inventory of third-party AI agents connected to corporate systems via OAuth?			
Can we identify every active OAuth token and map third-party client IDs to the approved vendor list?			
Do we know which employees have connected AI agents with delegated access to sensitive systems (email, financial portals, CRM, document stores)?			
Are agent actions logged separately from human actions, or are they attributed to the employee’s credential?			
Does our SIEM or identity platform surface AI agent behavior as distinct from authorized human activity?			
Do we have a sanctioned AI agent authorization workflow (name, vendor, scope, security review)?			
Does our Acceptable Use Policy explicitly address autonomous AI agents — not just software?			
Have we trained employees that authorizing an AI agent extends their attack surface to their inbox?			

AGENT INVENTORY (list known AI agents with delegated access, permission scope, and current status)

Agent Name / Tool	Connected Systems / Scope	Sanctioned?	Owner

02 OAuth & Permission Audit

Shadow Agents operate inside the employee's permission envelope. Audit the scope of delegated access and the platforms in scope for each agent.

Question	Yes	No	Unknown / Gap Notes
For each known agent, has the full OAuth permission scope been reviewed by security?			
Are agents with access to financial systems, client portals, or sensitive data stores identified?			
Is there a process to detect permission scope creep as agents accumulate access across integrated platforms?			
Can we identify agents connected to enterprise automation platforms (Zapier, Make, Power Automate)?			
Is there alerting when a new OAuth grant is made to an unrecognized third-party client ID?			
Have we assessed whether prompt injection via corporate email can reach any connected agent?			

PERMISSION SCOPE REVIEW: For each high-risk agent, document delegated access and approval status

Agent	Systems with Delegated Access	Scope Reviewed by Security?	Gap / Action

03 Detection Baseline

Standard monitoring is built for unauthorized access. Shadow Agents use authorized credentials — no alert fires. Detection requires identity-aware agent monitoring and OAuth audit cadence.

Question	Yes	No	Unknown / Gap Notes
Does your SIEM differentiate between actions taken by a human vs. an AI agent on the same credential?			
Is there an OAuth token review cadence that would surface unrecognized third-party client IDs?			
Do you have AI agent behavioral monitoring deployed for agents with access to sensitive systems?			
Is there detection for prompt injection via email targeting agents connected to corporate systems?			
Can your DLP controls detect data movement initiated by an agent vs. a human on the same platform?			
Is there alerting for an agent drafting or sending communications outside its normal pattern?			
Have you tested detection capability with a simulated Shadow Agent scenario?			

04 Governance Gap — Who Owns What

Shadow Agent's access was authorized. The employee granted it. Map ownership across the identity, policy, and IR surface before an incident surfaces the gap.

Function	Owner (Name / Role)	Last Reviewed	Gap
OAuth token inventory and third-party agent audit			
AI agent authorization workflow and sanctioned vendor list			
Acceptable Use Policy — autonomous agent clause			
Identity governance — human-delegated agent scope			
Incident response — agent-in-chain determination			
BEC training update — agent as proxy attack surface			
Vendor security review — AI agent category			

05 Five Questions for Your Next Executive Meeting

#	Question	Your Answer / Status
01	Do we have an inventory of AI agents operating in our environment with delegated access to employee credentials and corporate systems?	
02	If an employee's AI agent took an unauthorized action today — sent an email, moved data, initiated a transaction — how long before we would know, and how would we reconstruct what happened?	
03	Does our Acceptable Use Policy address autonomous AI agents specifically, or only unauthorized software?	
04	Are we training employees that authorizing an AI agent to act on their behalf extends their attack surface to every instruction that agent can receive?	
05	What is the business justification for the AI tools currently operating in our environment with the broadest permission scopes?	

06 Directives — Assign an Owner and a Date

#	Audience	Directive	Owner	Done By
01	CISO	Run an OAuth inventory. Pull every active token across your identity platform. Map every third-party client ID to the approved vendor list. Flag every unrecognized ID as a potential shadow agent with delegated access to human credentials.		
02	CISO	Establish a sanctioned AI agent authorization workflow before restricting access. Agent name, vendor, permission scope, business justification, security review. Make the sanctioned path easier than the shadow path.		
03	CISO	Update the Acceptable Use Policy with an explicit agent authorization clause. Name autonomous action specifically — not just data access. Most AUPs address tools that store data. This one acts.		
04	CISO	Extend your NHI program to include human-delegated AI agents. A third-party agent under a human OAuth token is a non-human actor in a human identity envelope. Governance controls need to account for agent behavior, not just credential validity.		
05	CISO	Add a distinct AI agent review tier to your vendor security framework — separate from SaaS. These tools process instructions and take autonomous action based on what they read.		
06	IR	Update IR methodology: for every incident involving AI-assisted workflows, explicitly determine whether an autonomous agent was in the action chain. Make it a required IR step, not an optional check.		
07	IR	Update BEC training to address agent-mediated attacks. Employees who authorize agents must understand that an attacker who reaches their inbox now reaches their agent. The phishing target is the human's autonomous proxy.		
08	IR	Stop attributing agent actions to the human credential. Build the capability to distinguish human-initiated from agent-initiated actions on delegated OAuth tokens.		
09	IR	Rank agents by exposure: highest permission scope + broadest OAuth delegation + no behavioral monitoring = highest Shadow Agent exposure. Close governance gaps from the top.		
10	IR	Run a cross-functional accountability exercise: if an employee's agent initiated a wire transfer today based on a phishing email, who detects it, who owns the response, and what do we tell the board?		